20 projets réseaux, systèmes et sécurité

Catalogue de 20 projets complexes et progressifs, avec objectifs, notions à apprendre, outils, ressources, étapes, documentation et la plateforme commune LabHub pour les valoriser.

Comment lire ce catalogue

Ce document applique la logique du catalogue de projets logiciels au domaine réseaux, systèmes et sécurité : 20 projets complexes, classés par difficulté croissante, qui couvrent l'infrastructure réseau, l'administration système Linux et Windows, la sécurité défensive (blue team), offensive (red team), le cloud, l'automatisation et la gouvernance. Pour chaque projet : objectif et exigences, notions théoriques à rechercher avant de pratiquer, outils et plateformes, ressources d'apprentissage, étapes de réalisation, compétences acquises, façon de documenter (de la théorie à la pratique) et manière de le mettre en valeur, soit par une plateforme dédiée quand le projet s'y prête, soit via la plateforme commune décrite plus bas.

Projets

20

6 réseaux et systèmes · 8 sécurité défensive et offensive · 6 cloud, automatisation, gouvernance

Matériel requis

1 PC

16 Go de RAM minimum (32 Go recommandés), SSD 500 Go, virtualisation activée ; un compte cloud gratuit pour les projets 17 et 20

Ordre conseillé. Le projet 01 (home lab) est le socle de tous les autres : il fournit l'hyperviseur, les réseaux virtuels et le pare-feu que les projets suivants réutilisent. Ensuite : *Intermédiaire* (01 à 06), *Avancé* (07 à 14), *Expert* (15 à 20). Le projet 20 (gouvernance et audit) s'applique à tout le lab construit et sert de projet de synthèse.

Méthodologie commune : de la théorie à la pratique documentée

Un projet d'infrastructure ne produit pas de code applicatif mais des configurations, des schémas, des preuves de tests et des procédures. Chaque projet suit six phases ; chaque phase produit un document versionné dans un dépôt Git (`lab/<numero>-<nom>/`) qui alimente la plateforme commune.

Phases communes à tous les projets et livrable de chaque phase

Phase	Activités	Livrable
1. Étude théorique	Lire, suivre un cours, lister les notions clés, rédiger des fiches de synthèse avec vos propres mots et schémas.	`01-theorie.md` : fiches de concepts, glossaire, sources
2. Conception	Schéma d'architecture (draw.io), plan d'adressage IP, matrice de flux, choix argumentés (ADR), prérequis matériels et logiciels.	`02-conception.md`, `schema.drawio`, `adressage.xlsx`
3. Réalisation	Déploiement pas à pas dans le lab, captures d'écran horodatées, sauvegarde de toutes les configurations dans Git, scripts d'automatisation.	`03-procedure.md`, dossier `configs/`, `scripts/`
4. Validation	Plan de tests (fonctionnels, sécurité, résilience), résultats, captures Wireshark, scans, métriques.	`04-tests.md`, `captures/`, rapports d'outils
5. Retour d'expérience	Incidents rencontrés et résolutions, erreurs à éviter, limites, pistes d'amélioration.	`05-retex.md`
6. Publication	Page de synthèse sur la plateforme commune, article de blog, vidéo courte de démonstration, badge ou certification associée.	Page projet publiée, article, vidéo

+ Modèle de documentation d'un projet (structure du dossier et de la page)

Plateforme commune : « LabHub », le portfolio vivant du laboratoire

La majorité des projets réseaux et sécurité ne produisent pas d'application ; ils produisent des infrastructures, des configurations et des rapports. La plateforme commune les rend visibles et vérifiables. Elle combine un site de documentation statique (simple, robuste) et une application web légère qui affiche l'état réel du lab. Elle constitue elle-même un projet logiciel à part entière et réutilise les compétences du premier catalogue.

Composants de la plateforme commune

Composant	Technologie proposée	Rôle
Site de documentation	MkDocs Material (ou Docusaurus) généré depuis le dépôt Git `lab/`	Une page par projet suivant le modèle ci-dessus, recherche plein texte, schémas draw.io intégrés, versionnement automatique par CI.
Application « tableau de bord du lab »	Next.js + NestJS (ou Django) · PostgreSQL	Fiches projets (statut, compétences, badges), inventaire des machines et réseaux synchronisé depuis NetBox, état de santé en direct via l'API Prometheus / Zabbix, chronologie des incidents, galerie de rapports PDF, page « CV technique » générée.
Source de vérité infrastructure	NetBox	Inventaire des VLAN, adresses IP, VM, câblage ; alimenté par Ansible (projet 08).
Supervision intégrée	Grafana (panneaux embarqués), Wazuh (indicateurs)	Montre que le lab fonctionne réellement : disponibilité, alertes, événements de sécurité des 7 derniers jours.
Blog et vidéos	Section articles du site + chaîne YouTube ou PeerTube	Un article de retour d'expérience par projet ; démonstrations de 5 minutes.
Dépôts publics	GitHub / GitLab : `lab-configs`, `ansible-lab`, `detection-rules`, `scripts`	Preuves techniques, configurations anonymisées, règles de détection, scripts.
Hébergement	VPS durci (projet 10) derrière reverse proxy Traefik ou Caddy, TLS via Let's Encrypt, SSO Keycloak (projet 15)	La plateforme elle-même est un exemple de déploiement sécurisé.

Fonctionnalités de l'application LabHub

- Catalogue des 20 projets avec statut (planifié, en cours, terminé), niveau, compétences, durée réelle.
- Fiche projet : résumé, schéma interactif, liens vers documentation, dépôt, rapport PDF, vidéo.
- Carte du lab : topologie générée depuis NetBox, état en direct de chaque nœud.
- Matrice de compétences (réseau, système, sécurité, cloud, automatisation) alimentée par les projets terminés.
- Journal d'incidents et de retours d'expérience, recherche par tag (protocole, outil, technique MITRE ATT&CK).
- Page publique « CV technique » exportable en PDF, page privée d'administration.

- Intégration des certifications et badges (Credly, TryHackMe, Hack The Box).

Étapes de réalisation de la plateforme

1. Semaine 1 : dépôt `lab/` avec le modèle de documentation, MkDocs Material, CI GitHub Actions qui publie sur GitHub Pages.
2. Semaine 2 : modèle de données de LabHub (projet, compétence, machine, incident, ressource), API, authentification.
3. Semaine 3 : interface catalogue et fiches projets, import des pages MkDocs par référence.
4. Semaine 4 : intégration NetBox et Grafana, carte du lab.
5. Ensuite : chaque projet terminé ajoute sa fiche, ses badges et ses preuves ; la plateforme évolue avec le lab.

Vue d'ensemble des 20 projets

Les 20 projets, leur domaine, leurs outils principaux, le niveau et le mode de valorisation

N°	Projet	Domaine	Outils principaux	Niveau	Valorisation
01	Home lab virtualisé et réseau segmenté	Systèmes / réseau	Proxmox VE, OPNsense, VLAN, Linux	Intermédiaire	Plateforme commune (socle)
02	Réseau d'entreprise multi-sites simulé	Réseau	GNS3 / EVE-NG, Cisco IOS, OSPF, HSRP, ACL	Intermédiaire	Plateforme commune
03	Annuaire Active Directory et intégration Linux	Systèmes	Windows Server, AD DS, GPO, Samba, SSSD	Intermédiaire	Plateforme commune
04	Pare-feu, IDS/IPS et filtrage applicatif	Sécurité réseau	OPNsense, Suricata, Zenarmor, Squid	Intermédiaire	Plateforme commune
05	PKI interne, TLS et contrôle d'accès 802.1X	Sécurité	OpenSSL, step-ca, FreeRADIUS, EAP-TLS	Intermédiaire	Plateforme dédiée possible (portail de certificats)
06	Supervision, métriques et journalisation centralisée	Systèmes	Prometheus, Grafana, Zabbix, Loki ou ELK	Intermédiaire	Intégré à la plateforme commune
07	VPN site à site et accès distant	Réseau / sécurité	WireGuard, strongSwan (IPsec), OpenVPN	Avancé	Plateforme commune
08	Infrastructure as Code et automatisation réseau	Automatisation	Ansible, Terraform, NetBox, Nornir, GitLab CI	Avancé	Dépôts publics + plateforme commune
09	Cluster Kubernetes sécurisé et pipeline DevSecOps	Systèmes / sécurité	k3s ou kubeadm, Cilium, Falco, Trivy, Vault	Avancé	Héberge la plateforme commune
10	Durcissement Linux et Windows conforme CIS / ANSSI	Sécurité système	OpenSCAP, Lynis, auditd, SELinux, AppArmor	Avancé	Plateforme dédiée possible (tableau de conformité)
11	SOC et SIEM : détection et réponse	Blue team	Wazuh, Sysmon, Sigma, MITRE ATT&CK, TheHive	Avancé	Plateforme dédiée (portail SOC)
12	Laboratoire de tests d'intrusion et rapport professionnel	Red team	Kali, Nmap, Burp Suite, Metasploit, HTB	Avancé	Plateforme commune (rapports)
13	Attaque et défense Active Directory	Purple team	GOAD, BloodHound, Impacket, Wazuh	Avancé	Plateforme commune

N°	Projet	Domaine	Outils principaux	Niveau	Valorisation
14	Haute disponibilité, sauvegardes et plan de reprise	Systèmes	HAProxy, Keepalived, Ceph ou ZFS, Proxmox Backup, Restic	Avancé	Plateforme commune
15	Zero Trust : identité, SSO, MFA et accès sécurisé	Sécurité / identité	Keycloak, Authelia, Teleport, Tailscale/Headscale	Expert	Protège la plateforme commune
16	Honeypots et renseignement sur les menaces	Blue team	T-Pot, Cowrie, MISP, OpenCTI	Expert	Plateforme dédiée (tableau de bord des attaques)
17	Cloud hybride sécurisé	Cloud	AWS ou Azure, Terraform, VPN, IAM, CloudTrail	Expert	Plateforme commune
18	Investigation numérique et réponse à incident	DFIR	Velociraptor, Volatility, Autopsy, KAPE, Plaso	Expert	Plateforme commune (rapports)
19	Simulation d'adversaire et purple teaming	Red / blue team	Caldera, Atomic Red Team, Sliver, Wazuh	Expert	Plateforme dédiée possible (couverture ATT&CK)
20	Gouvernance, analyse de risques et audit du lab	GRC	ISO 27001, NIST CSF, EBIOS RM, CIS Controls	Expert	Plateforme dédiée possible (registre des risques)

+ Plateformes d'apprentissage et certifications de référence (utilisées dans plusieurs projets)

01 · Home lab virtualisé et réseau segmenté

Domaine	Virtualisation, réseau local, administration Linux
Niveau	Intermédiaire (socle)
Durée indicative	3 à 4 semaines
Valorisation	Plateforme commune : page « architecture du lab » et carte NetBox

Objectif et exigences

Construire l'environnement qui hébergera tous les projets suivants : un hyperviseur, un pare-feu virtuel, des réseaux segmentés en VLAN (management, serveurs, utilisateurs, DMZ, lab d'attaque isolé), des modèles de machines virtuelles et une procédure de sauvegarde. Exigences : isolation stricte du réseau d'attaque, accès administrateur uniquement depuis le VLAN de management, modèles Linux et Windows déployables en moins de 5 minutes, documentation complète de l'adressage.

Notions à rechercher et apprendre

- Virtualisation : hyperviseurs de type 1 et 2, KVM/QEMU, conteneurs LXC, allocation CPU/RAM, stockage (LVM, ZFS), snapshots, cloud-init.
- Réseau : modèle OSI et TCP/IP, adressage IPv4 et CIDR, sous-réseaux, VLAN (802.1Q), ponts Linux et Open vSwitch, passerelle, NAT, DHCP, DNS.
- Pare-feu : filtrage à états, zones, règles par défaut « tout refuser », journalisation.
- Linux : gestion des services systemd, SSH par clés, sudo, paquets, journaux.

Outils, plateformes et ressources

- Proxmox VE (gratuit) ou alternative VMware Workstation / VirtualBox si une seule machine ; OPNsense ou pfSense comme pare-feu ; Debian, Ubuntu Server, Windows Server évaluation 180 jours ; NetBox ; draw.io.
- Ressources : documentation Proxmox, Learn Linux TV (série Proxmox), documentation OPNsense, cours « Networking Fundamentals » de Practical Networking, chapitre réseau de Linux Journey.

Étapes de réalisation

1. Théorie : fiches sur VLAN, sous-réseaux, filtrage à états ; exercice d'adressage sur papier.
2. Conception : schéma du lab (5 VLAN), plan d'adressage, matrice de flux entre zones, dimensionnement des VM.
3. Installation de Proxmox, configuration du pont VLAN-aware, stockage ZFS, dépôt de modèles.
4. Déploiement d'OPNsense avec une interface par VLAN, règles de base, DHCP et DNS par zone.
5. Création de modèles cloud-init (Debian, Ubuntu) et d'un modèle Windows Server avec sysprep.
6. Sauvegardes planifiées des VM (Proxmox Backup Server ou vzdump) et test de restauration.
7. Inventaire de tout le lab dans NetBox ; validation : tests de connectivité et d'isolation entre VLAN (ping, nmap, captures).

Compétences acquises

- Administration d'un hyperviseur et gestion du stockage et des sauvegardes.
- Conception et mise en œuvre d'un réseau segmenté par VLAN avec pare-feu inter-zones.
- Industrialisation de la création de machines (modèles, cloud-init).
- Documentation d'infrastructure (schémas, adressage, inventaire).

Documentation et mise en valeur

Livrables : schéma physique et logique, tableau d'adressage, matrice de flux, procédure d'installation reproductible, rapport de tests d'isolation avec captures nmap, procédure de restauration testée. Sur la plateforme commune, ce projet devient la page « Architecture du lab » que toutes les autres pages référencent ; la carte NetBox y est affichée en direct.

02 · Réseau d'entreprise multi-sites simulé

Domaine	Réseau (commutation, routage, services)
Niveau	Intermédiaire (niveau CCNA)
Durée indicative	5 à 6 semaines
Valorisation	Plateforme commune : topologies, configurations, captures

Objectif et exigences

Concevoir et configurer le réseau d'une entreprise fictive de trois sites (siège, agence, centre de données) avec redondance, routage dynamique, qualité de service et sécurité des équipements. Exigences : convergence après panne de lien en moins de 5 secondes, aucun accès non authentifié aux équipements, séparation voix / données / invités, connectivité IPv6 en parallèle d'IPv4, documentation au standard d'un dossier d'architecture technique.

Notions à rechercher et apprendre

- Commutation : VLAN, trunks, VTP, STP / RSTP / MSTP, EtherChannel (LACP), sécurité des ports, DHCP snooping, Dynamic ARP Inspection.
- Routage : statique, OSPF multi-aires, EIGRP ou BGP de base, redistribution, routage inter-VLAN, HSRP / VRRP, NAT, PBR.
- Services : DHCP relais, DNS, NTP, SNMPv3, syslog, NetFlow.
- IPv6 : adressage, SLAAC, DHCPv6, OSPFv3, double pile.
- Sécurité : ACL standard et étendues, AAA, SSH, plans de contrôle et de gestion, QoS (classification, files).

Outils, plateformes et ressources

- GNS3 ou EVE-NG Community (images Cisco IOSv / IOL, ou alternatives libres : VyOS, Arista cEOS, FRRouting) ; Packet Tracer pour les premiers exercices ; Wireshark ; iperf3.
- Ressources : Cisco Networking Academy (CCNA 1 à 3), Jeremy's IT Lab (cours et labs gratuits), livre « CCNA 200-301 Official Cert Guide » (Odom), documentation FRRouting, RFC 2328 (OSPF), RFC 4861 (IPv6 ND).

Étapes de réalisation

1. Théorie : un chapitre CCNA par semaine avec fiches ; labs Packet Tracer associés.
2. Conception : topologie hiérarchique (cœur, distribution, accès) par site, plan VLAN et IP v4/v6, choix OSPF multi-aires (ADR), plan de QoS.
3. Commutation : VLAN, trunks, RSTP, EtherChannel, sécurité de couche 2 sur le site principal, puis réplication.
4. Routage : inter-VLAN, OSPF entre sites via liens WAN simulés, HSRP sur les passerelles, NAT vers Internet simulé.
5. Services et gestion : DHCP, DNS, NTP, SNMPv3, syslog vers le collecteur du projet 06, AAA local puis RADIUS (projet 05).
6. IPv6 en double pile et OSPFv3.
7. Validation : tests de convergence (couper un lien, chronométrer), captures Wireshark des protocoles, vérification des ACL, tests iperf de la QoS.

8. Sauvegarde de toutes les configurations dans Git avec un script (Netmiko) : première étape vers le projet 08.

Compétences acquises

- Conception de réseau hiérarchique et redondant, adressage v4/v6.
- Configuration et dépannage de la commutation et du routage dynamique.
- Sécurisation des équipements et de la couche 2.
- Analyse de protocoles avec Wireshark ; rédaction d'un dossier d'architecture technique.

Documentation et mise en valeur

Livrables : dossier d'architecture technique (DAT) avec topologies L1/L2/L3, tableau des VLAN et adresses, configurations commentées dans Git, rapport de tests de convergence avec chronométrages et captures, fiches de dépannage. Sur la plateforme commune : page du projet avec topologie interactive (draw.io), lien vers le dépôt `lab-configs` et les captures ; le fichier de projet GNS3 exporté est fourni pour reproduction.

03 · Annuaire Active Directory et intégration Linux

Domaine	Systèmes Windows et Linux, identité
Niveau	Intermédiaire
Durée indicative	4 à 5 semaines
Valorisation	Plateforme commune ; réutilisé par les projets 11, 13 et 15

Objectif et exigences

Mettre en place l'annuaire d'entreprise : domaine Active Directory avec deux contrôleurs, DNS et DHCP intégrés, unités d'organisation, stratégies de groupe, partages de fichiers avec droits, serveur d'impression, puis intégration de postes et serveurs Linux au domaine. Exigences : modèle d'administration par niveaux (tiering), aucun compte administrateur du domaine utilisé au quotidien, mots de passe conformes à une politique, sauvegarde de l'état système et test de restauration d'un contrôleur.

Notions à rechercher et apprendre

- AD DS : forêt, domaine, sites, contrôleurs, catalogue global, réplication, rôles FSMO, schéma, DNS intégré (zones, SRV).
- Kerberos et NTLM : tickets TGT / TGS, SPN, délégation ; LDAP et LDAPS.
- GPO : ordre d'application, filtrage de sécurité, préférences, modèles ADMX, baselines de sécurité Microsoft.
- Modèle d'administration en tiers (Tier 0/1/2), comptes de service gérés (gMSA), LAPS.
- Intégration Linux : SSSD, realmd, Kerberos client, Samba, sudo via l'annuaire, montage de partages.

Outils, plateformes et ressources

- Windows Server 2022 (évaluation), Windows 11 Entreprise (évaluation), RSAT, PowerShell, Debian/Rocky Linux, Samba, SSSD ; Microsoft Security Compliance Toolkit ; PingCastle (audit AD).
- Ressources : Microsoft Learn (parcours AZ-800), documentation ANSSI « Recommandations de sécurité relatives à Active Directory », chaîne « MSFT WebCast », documentation Red Hat « Integrating RHEL with AD », blog ADSecurity.org.

Étapes de réalisation

1. Théorie : fiches Kerberos, réplication, GPO, tiering ; schéma du fonctionnement d'une ouverture de session.
2. Conception : nom de domaine, plan d'OU, convention de nommage, groupes (AGDLP), politique de mots de passe, plan de tiering.
3. Déploiement du premier contrôleur (DNS, DHCP avec basculement), puis du second ; vérification de la réplication.
4. Création des OU, utilisateurs et groupes par script PowerShell depuis un CSV ; comptes d'administration par tiers.
5. GPO : baseline de sécurité, restrictions de connexion par tiers, mappage de lecteurs, configuration du pare-feu Windows, LAPS.

6. Serveur de fichiers (partages, quotas, FSRM) et serveur d'impression ; jonction des postes Windows.
7. Intégration Linux : jonction avec realmd/SSSD, connexion avec compte AD, sudo par groupe AD, partage Samba avec ACL.
8. Audit avec PingCastle, correction des points relevés, sauvegarde et restauration d'un contrôleur.

Compétences acquises

- Administration d'Active Directory, DNS, DHCP et GPO.
- Sécurisation de l'annuaire (tiering, LAPS, baselines) et audit.
- PowerShell pour l'automatisation de l'administration.
- Interopérabilité Windows / Linux (Kerberos, SSSD, Samba).

Documentation et mise en valeur

Livrables : dossier de conception de l'annuaire (OU, groupes, nommage), catalogue des GPO avec justification, scripts PowerShell commentés, rapport PingCastle avant/après, procédure d'intégration Linux, procédure de restauration testée. Sur la plateforme commune : page projet avec le rapport PingCastle « avant / après » comme preuve chiffrée d'amélioration.

04 · Pare-feu, IDS/IPS et filtrage applicatif

Domaine	Sécurité réseau
Niveau	Intermédiaire
Durée indicative	4 semaines
Valorisation	Plateforme commune ; alertes remontées au SOC (projet 11)

Objectif et exigences

Transformer le pare-feu du lab en passerelle de sécurité complète : politique de filtrage documentée par zone, détection et prévention d'intrusion, filtrage web et DNS, publication sécurisée d'un service en DMZ avec reverse proxy, journalisation exploitable. Exigences : matrice de flux appliquée à la lettre (tout ce qui n'est pas listé est refusé et journalisé), IPS actif sur la DMZ sans faux positif bloquant, blocage des domaines malveillants, tests d'attaque prouvant les détections.

Notions à rechercher et apprendre

- Filtrage à états, NAT (source, destination, 1:1), alias, planification des règles, anti-spoofing, journalisation.
- IDS/IPS : signatures vs anomalies, Suricata (règles ET Open, mode inline), faux positifs, réglage.
- Filtrage DNS (Unbound, listes de blocage, DNS over TLS), proxy web et inspection TLS (limites et éthique).
- DMZ et publication : reverse proxy (HAProxy ou Nginx), WAF (ModSecurity, CRS OWASP), certificats.
- GeoIP, limitation de débit, protection contre le balayage de ports.

Outils, plateformes et ressources

- OPNsense (ou pfSense), Suricata, Zenarmor (édition gratuite), Unbound, HAProxy, ModSecurity, Nmap, hping3, testmyids.com, OWASP Juice Shop comme cible en DMZ.
- Ressources : documentation OPNsense, documentation Suricata et Emerging Threats, guide ANSSI « Recommandations pour la définition d'une politique de filtrage réseau », OWASP CRS documentation, cours TryHackMe « Network Security » et « Snort/Suricata ».

Étapes de réalisation

1. Théorie : fiches sur le filtrage à états, NAT, fonctionnement d'un IDS, WAF.
2. Conception : matrice de flux complète (source, destination, port, justification, propriétaire), plan de journalisation, ADR IDS en mode détection puis prévention.
3. Mise en œuvre des règles par zone avec alias et descriptions ; règles de refus explicites journalisées.
4. Activation de Suricata sur WAN et DMZ, jeux de règles ET Open, période d'observation, réglage, passage en IPS sur la DMZ.
5. Filtrage DNS avec listes de blocage, DNS over TLS vers l'extérieur, blocage du DNS sortant direct.

6. Publication de Juice Shop en DMZ via HAProxy + ModSecurity CRS, certificat de la PKI (projet 05).
7. Tests : nmap depuis chaque zone, attaques web sur Juice Shop (bloquées par le WAF), téléchargement de fichiers de test EICAR, vérification des journaux ; envoi des journaux au collecteur (projet 06 / 11).

Compétences acquises

- Rédaction et application d'une politique de filtrage réseau.
- Déploiement et réglage d'un IDS/IPS, gestion des faux positifs.
- Publication sécurisée de services (reverse proxy, WAF, TLS).
- Tests de validation offensive de contrôles défensifs.

Documentation et mise en valeur

Livrables : matrice de flux versionnée, export de la configuration du pare-feu, rapport de réglage IDS (alertes avant/après), rapport de tests d'attaque avec captures d'alertes, procédure de publication d'un service. Sur la plateforme commune : page projet avec un panneau Grafana « alertes Suricata des 7 derniers jours » et la matrice de flux consultable.

05 · PKI interne, TLS et contrôle d'accès réseau 802.1X

Domaine	Cryptographie appliquée, sécurité réseau
Niveau	Intermédiaire à avancé
Durée indicative	4 à 5 semaines
Valorisation	Plateforme dédiée possible : portail de demande et d'inventaire de certificats

Objectif et exigences

Déployer une infrastructure à clés publiques à deux niveaux (autorité racine hors ligne, autorité intermédiaire émettrice), distribuer des certificats à tous les services du lab, automatiser leur renouvellement, puis utiliser la PKI pour authentifier les machines sur le réseau (802.1X avec EAP-TLS) et les administrateurs (certificats clients, clés SSH signées). Exigences : clé racine hors ligne et protégée, révocation fonctionnelle (CRL, OCSP), aucun certificat auto-signé restant dans le lab, un poste non authentifié placé automatiquement dans un VLAN invité.

Notions à rechercher et apprendre

- Cryptographie : symétrique / asymétrique, RSA et courbes elliptiques, hachage, signatures, échange de clés, TLS 1.2/1.3 (handshake, suites), PFS.
- PKI : X.509, chaînes de confiance, extensions (SAN, EKU), CSR, CRL, OCSP, HSM, cérémonie de clés, durée de vie, ACME.
- 802.1X : supplicant, authentificateur, serveur d'authentification, EAP-TLS / PEAP, RADIUS, attribution dynamique de VLAN, MAB.
- SSH : autorités de certification SSH, certificats d'hôte et d'utilisateur.

Outils, plateformes et ressources

- OpenSSL, step-ca (Smallstep) ou EJBCA / AD CS pour comparer, FreeRADIUS, wpa_supplicant, commutateur virtuel supportant 802.1X (Cisco IOSv dans GNS3 ou un commutateur physique d'occasion), certbot / acme.sh, testssl.sh, Wireshark.
- Ressources : cours Cryptography I (Coursera, Dan Boneh), documentation Smallstep, RFC 5280 (X.509), RFC 8446 (TLS 1.3), guide ANSSI « Recommandations de sécurité relatives à TLS », documentation FreeRADIUS, wiki 802.1X de Cisco.

Étapes de réalisation

1. Théorie : fiches cryptographie et TLS ; décodage manuel d'un certificat et d'un handshake dans Wireshark.
2. Conception : hiérarchie de la PKI, politique de certification (durées, algorithmes, usages), procédure de cérémonie de la racine, plan de distribution des certificats, plan 802.1X par VLAN.
3. Création de la racine sur une VM hors ligne (puis éteinte et exportée), de l'intermédiaire avec step-ca, publication de la CRL et d'OCSP.
4. Distribution de la racine aux clients (GPO pour Windows, paquet pour Linux), émission automatisée via ACME pour les services web du lab, renouvellement planifié.

5. Remplacement de tous les certificats auto-signés (Proxmox, OPNsense, Grafana…) ; vérification avec testssl.sh.
6. FreeRADIUS avec EAP-TLS, certificats machine, configuration 802.1X du commutateur, VLAN dynamique, VLAN invité pour les échecs, MAB pour les imprimantes.
7. Autorité SSH : certificats d'hôte et d'utilisateur avec durée courte ; révocation d'un certificat et vérification de son rejet.
8. Tests : poste sans certificat placé en VLAN invité, certificat révoqué refusé, captures de l'échange EAP.

Compétences acquises

- Compréhension opérationnelle de la cryptographie et de TLS.
- Conception et exploitation d'une PKI d'entreprise, gestion du cycle de vie des certificats.
- Contrôle d'accès réseau 802.1X et RADIUS.
- Automatisation ACME et durcissement des configurations TLS.

Documentation et mise en valeur

Livrables : politique de certification, compte rendu de cérémonie de clés, schéma de la PKI, procédures d'émission / renouvellement / révocation, rapport testssl.sh avant/après, captures EAP-TLS. Plateforme dédiée envisageable : un **portail de certificats** (application web Python/FastAPI ou Go) où l'on demande un certificat, visualise l'inventaire, les dates d'expiration et les révocations, avec alertes avant expiration ; il s'appuie sur l'API de step-ca et démontre la maîtrise du sujet de bout en bout.

06 · Supervision, métriques et journalisation centralisée

Domaine	Administration système, observabilité
Niveau	Intermédiaire
Durée indicative	4 semaines
Valorisation	Directement intégré à la plateforme commune (panneaux Grafana en direct)

Objectif et exigences

Rendre le lab observable : métriques de tous les équipements et services, journaux centralisés et recherchables, tableaux de bord, alertes envoyées par e-mail et messagerie, pages de statut. Exigences : découverte automatique des nouvelles machines, rétention de 30 jours de journaux, alertes pertinentes (pas de bruit) avec procédure associée, disponibilité mesurée pour chaque service, journaux horodatés de manière fiable (NTP).

Notions à rechercher et apprendre

- Métriques, journaux, traces ; modèles pull (Prometheus) vs push ; SNMP (MIB, OID, v3), exporters, PromQL.
- Journalisation : syslog (RFC 5424), journald, Windows Event Log, agents (Promtail, Filebeat, rsyslog), analyse et normalisation, rétention et rotation.
- Alerting : seuils, symptômes vs causes, SLI/SLO, fatigue d'alerte, astreinte.
- Synchronisation temporelle NTP / chrony ; importance pour la corrélation et la forensique.

Outils, plateformes et ressources

- Prometheus, node_exporter, windows_exporter, snmp_exporter, blackbox_exporter, Grafana, Alertmanager, Loki + Promtail (ou Elastic Stack), Zabbix (pour comparer une approche « classique »), Uptime Kuma, chrony.
- Ressources : documentation Prometheus et Grafana, livre « Prometheus: Up & Running », Grafana Labs tutorials, documentation Zabbix, cours KodeKloud « Prometheus Certified Associate ».

Étapes de réalisation

1. Théorie : fiches métriques / journaux, PromQL de base, SNMP.
2. Conception : liste des sources, ce qu'il faut mesurer par service (méthode RED / USE), politique de rétention, canaux d'alerte, ADR Prometheus + Loki vs Zabbix vs ELK.
3. Serveur NTP interne (chrony) et configuration de tous les équipements.
4. Prometheus et exporters sur toutes les VM Linux et Windows, snmp_exporter pour les équipements réseau, blackbox pour les tests HTTP/ICMP.
5. Loki + Promtail (ou Filebeat) : journaux Linux, Windows, OPNsense, Suricata, équipements réseau via syslog.
6. Tableaux de bord Grafana par domaine (réseau, systèmes, sécurité, plateforme), pages de statut Uptime Kuma.
7. Règles d'alerte avec libellés de gravité, Alertmanager vers e-mail et Telegram/Discord ; une fiche de procédure par alerte.

8. Découverte automatique via fichiers générés par Ansible depuis NetBox (préfiguration du projet 08) ; validation par simulation de pannes.

Compétences acquises

- Déploiement d'une pile d'observabilité complète et PromQL.
- Collecte et normalisation de journaux hétérogènes.
- Conception d'alertes actionnables et de tableaux de bord lisibles.
- Culture SRE : SLI, SLO, procédures d'exploitation.

Documentation et mise en valeur

Livrables : cartographie des sources supervisées, catalogue des alertes avec procédures, tableaux de bord exportés en JSON, rapport de disponibilité mensuel. Intégration à la plateforme commune : les panneaux Grafana sont embarqués dans LabHub (disponibilité, charge, alertes) et prouvent en continu que le lab est réel et exploité ; le rapport de disponibilité mensuel est publié automatiquement.

07 · VPN site à site et accès distant

Domaine	Réseau et sécurité (chiffrement des communications)
Niveau	Avancé
Durée indicative	3 à 4 semaines
Valorisation	Plateforme commune ; sécurise l'accès au lab

Objectif et exigences

Relier deux sites du lab par un tunnel chiffré et offrir un accès distant sécurisé aux administrateurs, en comparant trois technologies (WireGuard, IPsec, OpenVPN). Exigences : tunnel site à site chiffré et redémarrant seul, accès distant avec authentification forte et certificats (PKI du projet 05), routage et pare-feu corrects entre sites, comparaison mesurée des performances, aucun accès administrateur exposé directement sur Internet.

Notions à rechercher et apprendre

- IPsec : IKEv2, phases 1 et 2, ESP, tunnel vs transport, PSK vs certificats, NAT-T.
- WireGuard : cryptographie moderne (Noise), clés, AllowedIPs, keepalive, roaming.
- OpenVPN : TLS, tun/tap, routage push, authentification par certificat + TOTP.
- Routage entre sites, split tunneling, DNS via VPN, MTU / MSS clamping.
- Concepts d'accès distant moderne (préparation du Zero Trust, projet 15).

Outils, plateformes et ressources

- WireGuard, strongSwan, OpenVPN (intégrés à OPNsense), iperf3, mtr, Wireshark ; Google Authenticator / FreeOTP pour le TOTP.
- Ressources : documentation WireGuard (whitepaper de Jason Donenfeld), documentation strongSwan, guide ANSSI « Recommandations de sécurité IPsec », wiki OPNsense, cours TryHackMe « VPN ».

Étapes de réalisation

1. Théorie : fiches IPsec / WireGuard / OpenVPN, schéma du chiffrement de chaque solution.
2. Conception : plan d'adressage des tunnels, matrice de flux inter-sites, ADR de choix par usage (site à site vs nomade).
3. Tunnel site à site WireGuard entre deux pare-feux, routage, règles de filtrage, redémarrage automatique.
4. Même tunnel en IPsec IKEv2 avec certificats de la PKI, pour comparaison.
5. Accès distant : WireGuard nomade et OpenVPN avec certificat client + TOTP, DNS interne, split tunneling maîtrisé.
6. Bastion d'administration accessible uniquement via le VPN ; suppression de toute exposition SSH/RDP directe.
7. Validation : captures Wireshark (trafic chiffré illisible), tests iperf3 et latence pour comparer les trois solutions, test de bascule après coupure.

Compétences acquises

- Déploiement et comparaison de technologies VPN.
- Conception d'un accès distant sécurisé avec MFA et certificats.
- Routage inter-sites et dépannage de MTU / MSS.
- Analyse comparative argumentée (sécurité, performance, exploitation).

Documentation et mise en valeur

Livrables : schéma des tunnels, configurations, tableau comparatif WireGuard / IPsec / OpenVPN (débit, latence, complexité, sécurité), procédure d'onboarding d'un administrateur nomade. Sur la plateforme commune : page projet avec le tableau comparatif et un schéma « comment j'accède au lab » servant aussi de documentation d'exploitation.

08 · Infrastructure as Code et automatisation réseau

Domaine	Automatisation, DevOps réseau
Niveau	Avancé
Durée indicative	5 à 6 semaines
Valorisation	Dépôts publics (preuves de code) + plateforme commune

Objectif et exigences

Rendre tout le lab reproductible et versionné : provisionnement des VM, configuration des systèmes, configuration des équipements réseau et de NetBox comme source de vérité, le tout piloté par Git et une chaîne CI/CD. Exigences : reconstruire une VM ou un service entièrement à partir du code, aucune configuration faite « à la main » sans être reportée dans le code, tests automatiques avant application, secrets chiffrés, NetBox comme référentiel unique de l'inventaire.

Notions à rechercher et apprendre

- Idempotence, gestion de configuration vs provisionnement, immutable vs mutable infrastructure.
- Ansible : inventaires (statique, dynamique depuis NetBox), rôles, playbooks, handlers, templates Jinja2, Ansible Vault, collections (réseau).
- Terraform : providers (Proxmox, NetBox), état, plan/apply, modules, variables.
- Automatisation réseau : Netmiko, NAPALM, Nornir, modèles de configuration, drift detection.
- CI/CD : GitLab CI ou GitHub Actions, lint (ansible-lint, yamllint), tests (Molecule), déploiement progressif, revue.
- Source de vérité : NetBox (modèle de données, API), génération de configuration depuis les données.

Outils, plateformes et ressources

- Ansible, Terraform, NetBox, Nornir/NAPALM/Netmiko, GitLab CE (auto-hébergé) ou GitHub, Molecule, pre-commit, SOPS ou Ansible Vault.
- Ressources : documentation Ansible et « Ansible for DevOps » (Jeff Geerling), documentation Terraform, chaîne « Jeff Geerling » (YouTube), documentation NetBox, livre « Network Programmability and Automation » (O'Reilly), cours KodeKloud Ansible/Terraform.

Étapes de réalisation

1. Théorie : fiches idempotence, Jinja2, modèle de données NetBox.
2. Conception : arborescence du dépôt `ansible-lab`, stratégie d'inventaire dynamique, plan de gestion des secrets, ADR Ansible + Terraform + NetBox.
3. Terraform : provisionnement des VM sur Proxmox à partir des modèles, création des enregistrements NetBox.
4. Ansible : rôles pour le socle Linux (utilisateurs, SSH, pare-feu, exporters du projet 06), rôle Windows via WinRM, chiffrement des secrets.
5. Automatisation réseau : génération des configurations des équipements depuis NetBox (Jinja2), application via Nornir/NAPALM, détection de dérive.

6. Inventaire dynamique Ansible depuis NetBox ; Prometheus et Loki configurés automatiquement pour toute nouvelle machine.
7. CI/CD : lint, tests Molecule, exécution en mode vérification (check) sur merge request, application après validation.
8. Validation : détruire puis reconstruire une VM entièrement par le code ; introduire une dérive manuelle et prouver sa détection.

Compétences acquises

- Infrastructure as Code (Terraform) et gestion de configuration (Ansible).
- Automatisation réseau pilotée par une source de vérité (NetBox).
- CI/CD d'infrastructure, tests et gestion des secrets.
- Culture GitOps et reproductibilité.

Documentation et mise en valeur

Livrables : dépôts publics `ansible-lab` et `terraform-lab` avec README, schéma du flux GitOps, démonstration de reconstruction, capture de la détection de dérive. Ces dépôts sont la vitrine « code » du portfolio ; sur la plateforme commune, la page projet met en avant le pipeline CI et l'inventaire NetBox synchronisé automatiquement.

09 · Cluster Kubernetes sécurisé et pipeline DevSecOps

Domaine	Conteneurs, systèmes, sécurité applicative
Niveau	Avancé
Durée indicative	6 semaines
Valorisation	Héberge la plateforme commune LabHub

Objectif et exigences

Déployer un cluster Kubernetes qui héberge la plateforme LabHub et d'autres services internes, en appliquant les bonnes pratiques de sécurité des conteneurs et une chaîne d'intégration continue « sécurisée par conception ». Exigences : images scannées et signées, politiques réseau « refus par défaut » entre pods, secrets gérés par un coffre, admission contrôlée (pas de conteneur privilégié), détection d'exécution anormale, sauvegarde et restauration du cluster.

Notions à rechercher et apprendre

- Conteneurs : namespaces, cgroups, images, registres, rootless, différence conteneur / VM.
- Kubernetes : pods, services, ingress, deployments, RBAC, namespaces, NetworkPolicy, PodSecurity, stockage persistant, Helm.
- Sécurité : scan d'images (Trivy), signature (cosign / Sigstore), politiques d'admission (Kyverno / OPA Gatekeeper), runtime security (Falco), CIS Kubernetes Benchmark (kube-bench).
- DevSecOps : SAST, SCA, secrets scanning, tests dans le pipeline, GitOps (Argo CD / Flux), gestion des secrets (Vault, External Secrets).

Outils, plateformes et ressources

- k3s ou kubeadm, Cilium (CNI + NetworkPolicy + Hubble), Traefik ou Nginx Ingress, Helm, Argo CD, HashiCorp Vault, Trivy, cosign, Kyverno, Falco, kube-bench, Gitea/GitLab + runners.
- Ressources : Kubernetes.io tutorials, « Kubernetes Up & Running », KodeKloud (CKA/CKS), documentation Cilium et Falco, OWASP « Kubernetes Security Cheat Sheet », cours « Killer Shell » CKS.

Étapes de réalisation

1. Théorie : fiches conteneurs, architecture Kubernetes, modèle RBAC, NetworkPolicy.
2. Conception : topologie du cluster (nœuds sur Proxmox), plan de namespaces et RBAC, stratégie de secrets, ADR k3s vs kubeadm et Cilium vs autres CNI.
3. Installation du cluster (Terraform + Ansible du projet 08), CNI Cilium, ingress, stockage persistant, sauvegarde (Velero).
4. Déploiement de la plateforme LabHub via Helm et Argo CD (GitOps).
5. Sécurité : Vault + External Secrets, Kyverno (interdire privileged, exiger limites et images signées), NetworkPolicy « deny all » puis ouvertures ciblées, Falco pour la détection runtime.

6. Pipeline DevSecOps : build d'image, scan Trivy, signature cosign, tests, déploiement GitOps ; échec du pipeline si vulnérabilité critique.
7. Audit : kube-bench (CIS), correction ; envoi des événements Falco au SOC (projet 11).
8. Validation : tenter de déployer un pod privilégié (refusé), un pod avec image non signée (refusé), déclencher une alerte Falco (shell dans un conteneur).

Compétences acquises

- Administration et sécurisation de Kubernetes (RBAC, NetworkPolicy, admission).
- Sécurité de la chaîne d'approvisionnement logicielle (scan, signature).
- GitOps et gestion des secrets.
- Détection d'intrusion au niveau conteneur.

Documentation et mise en valeur

Livrables : schéma du cluster, manifests et charts dans Git, rapport kube-bench avant/après, démonstration des refus d'admission, procédure de restauration Velero. Ce projet héberge LabHub : la plateforme commune tourne donc sur une infrastructure dont la sécurité est elle-même documentée et démontrée.

10 · Durcissement des systèmes conforme CIS / ANSSI

Domaine	Sécurité système (Linux et Windows)
Niveau	Avancé
Durée indicative	4 à 5 semaines
Valorisation	Plateforme dédiée possible : tableau de bord de conformité

Objectif et exigences

Élaborer et appliquer des référentiels de durcissement pour les serveurs Linux et Windows du lab, mesurer la conformité, automatiser l'application et suivre l'évolution dans le temps. Exigences : score de conformité mesuré avant / après, durcissement appliqué par Ansible/GPO (reproductible), aucune régression fonctionnelle, contrôle continu, gestion documentée des exceptions.

Notions à rechercher et apprendre

- Référentiels : CIS Benchmarks, guides ANSSI (durcissement GNU/Linux, Windows), DISA STIG, SCAP / OpenSCAP, notion de baseline et de profil (niveau 1/2).
- Linux : comptes et sudo, PAM, SSH durci, pare-feu (nftables), services minimaux, systemd hardening, montages (noexec, nosuid), audit (auditd), MAC (SELinux, AppArmor), intégrité (AIDE), mises à jour automatiques.
- Windows : baselines de sécurité, LAPS, restriction des privilèges, journalisation avancée, AppLocker/WDAC, désactivation de protocoles hérités (SMBv1, NTLMv1), BitLocker.
- Gestion des exceptions et acceptation du risque.

Outils, plateformes et ressources

- OpenSCAP + SCAP Security Guide, Lynis, CIS-CAT (édition gratuite), auditd, SELinux/AppArmor, AIDE, Ansible (rôles ANSSI/DevSec Hardening), Microsoft Security Compliance Toolkit, PolicyAnalyzer.
- Ressources : CIS Benchmarks (téléchargement gratuit), guides ANSSI, documentation OpenSCAP, projet « ansible-lockdown » (CIS/STIG), Microsoft Learn (baselines).

Étapes de réalisation

1. Théorie : lecture ciblée d'un CIS Benchmark Linux et d'un guide ANSSI ; fiches par thème (SSH, audit, MAC).
2. Conception : choix des référentiels et du niveau, périmètre, registre des exceptions, ADR.
3. Audit initial avec OpenSCAP et Lynis sur un serveur type : score et liste des écarts.
4. Écriture d'un rôle Ansible de durcissement Linux (idempotent), application sur un serveur de test, vérification de non-régression.
5. Durcissement Windows via GPO / baselines et scripts, audit CIS-CAT.
6. Contrôle continu : exécution planifiée des scans, remontée des scores dans Prometheus/Grafana (projet 06).

7. Généralisation à l'ensemble du lab via le pipeline du projet 08 ; documentation des exceptions justifiées.
8. Validation : comparaison des scores avant/après, tests fonctionnels des services durcis.

Compétences acquises

- Lecture et application de référentiels de sécurité reconnus.
- Durcissement Linux et Windows automatisé et mesurable.
- Gestion de la conformité dans le temps et des exceptions.
- Équilibre sécurité / disponibilité (non-régression).

Documentation et mise en valeur

Livrables : référentiel de durcissement du lab, rôles Ansible publiés, rapports OpenSCAP/CIS-CAT avant/après, registre des exceptions. Plateforme dédiée envisageable : un **tableau de bord de conformité** qui agrège les scores SCAP par machine et leur évolution (application web + base de résultats), montrant la progression de la posture de sécurité du lab.

11 · SOC et SIEM : détection et réponse

Domaine	Sécurité défensive (blue team)
Niveau	Avancé
Durée indicative	6 semaines
Valorisation	Plateforme dédiée : portail SOC (alertes, cas, couverture ATT&CK)

Objectif et exigences

Construire un centre opérationnel de sécurité pour le lab : collecte des journaux de sécurité de toutes les sources, détection basée sur des règles alignées sur MITRE ATT&CK, gestion des alertes en cas d'incident, et procédures de réponse. Exigences : couverture des principales sources (Windows/Sysmon, Linux, réseau, pare-feu, Kubernetes), règles de détection versionnées (Sigma), réduction des faux positifs, chaîne alerte → cas → réponse, tableau de bord de couverture ATT&CK.

Notions à rechercher et apprendre

- Fonctionnement d'un SOC, niveaux d'analystes, cycle de détection et réponse, pyramide de la douleur, kill chain.
- MITRE ATT&CK : tactiques, techniques, cartographie de la détection (Navigator).
- Sources et télémétrie : Sysmon (configuration), journaux Windows utiles, auditd, EDR vs SIEM.
- Détection : règles Sigma, langage de requête du SIEM, corrélation, seuils, allowlists.
- Réponse à incident : triage, confinement, playbooks, SOAR, gestion de cas.

Outils, plateformes et ressources

- Wazuh (SIEM/XDR) ou Elastic Security ; Sysmon + config SwiftOnSecurity/Olaf Hartong ; Sigma + sigmac ; MITRE ATT&CK Navigator ; TheHive + Cortex (gestion de cas et réponse) ; Shuffle (SOAR).
- Ressources : parcours TryHackMe « SOC Level 1/2 », LetsDefend, documentation Wazuh, dépôt SigmaHQ, MITRE ATT&CK, blog « Florian Roth », « The DFIR Report » pour des cas réels.

Étapes de réalisation

1. Théorie : fiches ATT&CK, kill chain, rôle du SIEM ; cartographie des sources du lab.
2. Conception : architecture de collecte, liste des cas d'usage de détection prioritaires (mappés ATT&CK), plan de gestion des alertes, ADR Wazuh vs Elastic.
3. Déploiement du SIEM, agents sur Windows/Linux, Sysmon configuré, collecte du pare-feu, Suricata, Kubernetes/Falco.
4. Écriture et import de règles de détection (Sigma converties) : force brute, mouvement latéral, persistance, exfiltration, désactivation de logs, etc.
5. Réglage : génération de faux positifs, création d'allowlists, ajustement des seuils.
6. Chaîne de réponse : intégration TheHive, création automatique de cas, playbooks de triage et de confinement, SOAR pour les actions simples (bloquer une IP sur OPNsense).

7. Tableau de bord de couverture ATT&CK (Navigator) montrant les techniques détectées.
8. Validation : exécuter des tests d'attaque (Atomic Red Team, projet 19) et vérifier la détection ; mesurer le délai de détection.

Compétences acquises

- Ingénierie de détection (Sigma, ATT&CK) et réglage des règles.
- Exploitation d'un SIEM et gestion des sources de télémétrie.
- Gestion des incidents (triage, cas, playbooks) et SOAR.
- Mesure et amélioration de la couverture de détection.

Documentation et mise en valeur

Livrables : architecture du SOC, dépôt `detection-rules` (Sigma), playbooks de réponse, matrice de couverture ATT&CK, rapports d'incidents simulés. Plateforme dédiée : un **portail SOC** (ou l'intégration dans LabHub) affichant les alertes récentes, les cas TheHive et la couverture ATT&CK ; c'est une vitrine forte pour un profil blue team.

12 · Laboratoire de tests d'intrusion et rapport professionnel

Domaine	Sécurité offensive (pentest)
Niveau	Avancé
Durée indicative	6 semaines (puis continu)
Valorisation	Plateforme commune : rapports et write-ups (contenu anonymisé)

Objectif et exigences

Monter un environnement d'entraînement offensif isolé, s'exercer méthodiquement (réseau, web, systèmes) et surtout produire des rapports de test d'intrusion de qualité professionnelle. Exigences : réseau d'attaque strictement isolé (aucun impact sur les autres VLAN ni sur Internet non maîtrisé), méthodologie reconnue suivie (PTES / OWASP), chaque exploitation documentée avec preuve, remédiations proposées et priorisées, rapport rédigé comme pour un client.

Notions à rechercher et apprendre

- Méthodologie : PTES, cyber kill chain, OWASP Testing Guide, catégories OWASP Top 10, gestion de la portée et de l'autorisation (éthique et légalité).
- Reconnaissance et scan : OSINT, Nmap (scripts NSE), énumération de services.
- Web : injections (SQL, commande), XSS, IDOR, SSRF, auth cassée, upload, désérialisation.
- Systèmes : exploitation de services vulnérables, élévation de privilèges Linux et Windows, credential dumping, pivoting.
- Post-exploitation, nettoyage, notation CVSS, rédaction de rapport.

Outils, plateformes et ressources

- Kali Linux ou Parrot, Nmap, Burp Suite (Community), ffuf, sqlmap, Metasploit, Hydra, John/Hashcat, linPEAS/winPEAS, Ligolo-ng ; cibles : Metasploitable, VulnHub, DVWA, OWASP Juice Shop, et plateformes en ligne Hack The Box, TryHackMe, PortSwigger Academy.
- Ressources : Hack The Box Academy, TryHackMe « Jr Penetration Tester », PortSwigger Web Security Academy (gratuit), livre « The Web Application Hacker's Handbook », « TCM Security Practical Ethical Hacking », modèles de rapports (TCM, PentesterLab).

Étapes de réalisation

1. Théorie : fiches méthodologie PTES et OWASP ; rappel du cadre légal (ne tester que ce qu'on possède ou ce qui est autorisé).
2. Conception : VLAN d'attaque isolé, cibles déployées, règle d'engagement écrite pour soi-même, modèle de rapport.
3. Entraînement structuré : un thème par semaine (reconnaissance, web, AD, élévation de privilèges), notes détaillées.
4. Mission fil rouge : traiter une cible complète de bout en bout (recon → exploitation → post-exploitation → nettoyage) comme un vrai engagement.
5. Corrélation défensive : vérifier ce que le SOC (projet 11) a détecté pendant les attaques.

6. Rédaction du rapport professionnel : synthèse pour la direction, détails techniques, preuves, CVSS, remédiations priorisées.
7. Validation : appliquer les remédiations proposées puis rejouer l'attaque pour prouver la correction.

Compétences acquises

- Méthodologie de test d'intrusion et état d'esprit offensif.
- Exploitation web, réseau et système, élévation de privilèges, pivoting.
- Notation des vulnérabilités et proposition de remédiations.
- Rédaction de rapports professionnels et communication du risque.

Documentation et mise en valeur

Livrables : rapports de pentest (anonymisés), write-ups de machines, cheat sheets personnelles, preuves de remédiation. Sur la plateforme commune : section « rapports » (PDF) et blog de write-ups ; les profils Hack The Box / TryHackMe et certifications (eJPT, PNPT) y sont liés comme preuves externes.

13 · Attaque et défense d'Active Directory

Domaine	Purple team (offensif + défensif sur AD)
Niveau	Avancé
Durée indicative	5 semaines
Valorisation	Plateforme commune : chaînes d'attaque et détections associées

Objectif et exigences

Comprendre en profondeur les attaques ciblant Active Directory et les défenses correspondantes, en jouant successivement l'attaquant et le défenseur sur un domaine délibérément vulnérable, puis en durcissant. Exigences : domaine de test isolé, chaque technique d'attaque suivie de sa détection (SIEM du projet 11) et de sa remédiation, réduction mesurable des chemins d'attaque (BloodHound avant/après), aucune de ces techniques exécutée hors du lab.

Notions à rechercher et apprendre

- Reconnaissance AD, énumération LDAP/SMB, chemins d'attaque (BloodHound).
- Attaques d'authentification : Kerberoasting, AS-REP roasting, Pass-the-Hash, Pass-the-Ticket, Overpass-the-Hash, DCSync, délégations (non contrainte, contrainte, basée sur les ressources).
- Élévation et persistance : ACL abusives, GPO abusives, Golden/Silver Ticket, ADCS (ESC1-ESC8).
- Défense : tiering, comptes protégés, gMSA, durcissement Kerberos, détection (event IDs, Sigma), LAPS, désactivation des protocoles hérités.

Outils, plateformes et ressources

- GOAD (Game of Active Directory) ou un domaine vulnérable maison, BloodHound/SharpHound, Impacket, Rubeus, Mimikatz, Certipy, CrackMapExec/NetExec ; côté défense : Wazuh, PingCastle, Purple Knight.
- Ressources : projet GOAD (Orange Cyberdefense), TryHackMe/HTB parcours AD, « The Hacker Recipes » (thehacker.recipes), ADSecurity.org, documentation Microsoft sur la sécurisation d'AD, guide ANSSI AD.

Étapes de réalisation

1. Théorie : fiches Kerberos (rappel projet 03) et chaque famille d'attaque expliquée avec un schéma.
2. Conception : déploiement de GOAD isolé, plan « attaque → détection → remédiation » par technique.
3. Cartographie initiale avec BloodHound ; identification des chemins vers Domain Admin.
4. Exécution des attaques une par une, avec captures ; vérification de la détection côté SIEM.
5. Remédiation après chaque technique (durcissement, désactivation, comptes protégés) ; nouvelle mesure BloodHound.
6. Focus ADCS : identifier et corriger un modèle de certificat vulnérable (ESC1).

7. Validation : rejouer les attaques après durcissement pour prouver qu'elles échouent ou sont détectées ; comparer les graphes BloodHound avant/après.

Compétences acquises

- Compréhension approfondie des attaques AD et de Kerberos.
- Détection et remédiation des techniques (approche purple team).
- Analyse de chemins d'attaque et réduction de la surface (BloodHound).
- Sécurisation avancée d'Active Directory et d'ADCS.

Documentation et mise en valeur

Livrables : matrice « technique / commande / détection / remédiation », captures BloodHound avant/après, règles de détection ajoutées au dépôt `detection-rules`, rapport de durcissement AD. Sur la plateforme commune : page très valorisante montrant la double compétence attaque et défense sur le sujet le plus recherché en entreprise.

14 · Haute disponibilité, sauvegardes et plan de reprise

Domaine	Ingénierie système, résilience
Niveau	Avancé
Durée indicative	4 à 5 semaines
Valorisation	Plateforme commune : preuves de bascule et de restauration

Objectif et exigences

Rendre les services critiques du lab résilients : redondance, répartition de charge, sauvegardes fiables selon la règle 3-2-1 et un véritable plan de reprise d'activité testé. Exigences : bascule automatique d'un service sans coupure perçue, sauvegardes chiffrées et vérifiées, objectifs de reprise définis (RTO/RPO) et respectés lors d'un test grandeur nature, restauration prouvée (pas seulement des sauvegardes qui « existent »).

Notions à rechercher et apprendre

- Disponibilité : redondance active/passive et active/active, load balancing (L4/L7), IP virtuelle (VRRP/Keepalived), health checks, quorum, split-brain.
- Réplication de données : bases (réplication PostgreSQL), stockage (ZFS send/receive, Ceph), cohérence.
- Sauvegarde : complète/incrémentale/différentielle, règle 3-2-1(-1-0), immuabilité, chiffrement, rétention (GFS), test de restauration.
- PRA/PCA : RTO, RPO, criticité des services, procédures, exercices.

Outils, plateformes et ressources

- HAProxy + Keepalived, PostgreSQL en réplication (Patroni en option), ZFS et/ou Ceph, Proxmox Backup Server, Restic ou BorgBackup (dépôt distant chiffré), MinIO avec object lock (immutabilité).
- Ressources : documentation HAProxy et Keepalived, documentation Proxmox Backup Server, documentation PostgreSQL (high availability), « Site Reliability Engineering » (Google), guides sur la règle 3-2-1.

Étapes de réalisation

1. Théorie : fiches HA, réplication, 3-2-1, RTO/RPO.
2. Conception : liste des services critiques et leur criticité, cibles RTO/RPO, architecture HA par service, stratégie de sauvegarde et plan de PRA, ADR.
3. Répartition de charge et VIP (HAProxy + Keepalived) devant un service web répliqué ; test de bascule.
4. Réplication d'une base de données et test de promotion du secondaire.
5. Sauvegardes : Proxmox Backup Server pour les VM, Restic/Borg pour les données applicatives, copie hors site chiffrée et immuable ; planification et vérification d'intégrité.
6. Rédaction du plan de reprise (rôles, étapes, ordre de redémarrage, contacts fictifs).
7. Validation : exercice de sinistre (arrêt brutal d'un nœud ou « perte » d'une VM), restauration chronométrée, comparaison au RTO/RPO cibles, corrections.

Compétences acquises

- Conception d'architectures à haute disponibilité (équilibrage, VIP, réplication).
- Stratégies de sauvegarde robustes et immuables.
- Élaboration et test d'un plan de reprise d'activité.
- Mesure et amélioration de la résilience (RTO/RPO).

Documentation et mise en valeur

Livrables : schémas HA, matrice de criticité, plan de sauvegarde, plan de reprise, rapport d'exercice de sinistre avec chronométrage. Sur la plateforme commune : page projet avec la vidéo d'un test de bascule et le rapport de restauration — des preuves concrètes rarement montrées et très appréciées des recruteurs.

15 · Zero Trust : identité, SSO, MFA et accès sécurisé

Domaine	Gestion des identités et des accès
Niveau	Expert
Durée indicative	5 à 6 semaines
Valorisation	Protège la plateforme commune (SSO réel devant LabHub)

Objectif et exigences

Remplacer le modèle « périmètre de confiance » par une architecture Zero Trust : chaque accès est authentifié, autorisé et chiffré, quel que soit l'emplacement. Mise en place d'un fournisseur d'identité central avec SSO et MFA, d'un proxy d'accès aux applications, d'un accès administrateur audité avec enregistrement de session, et d'un réseau maillé chiffré. Exigences : plus aucun mot de passe local sur les applications du lab, MFA obligatoire pour les accès d'administration, décision d'accès tenant compte de l'utilisateur, de l'appareil et du contexte, journalisation de tous les accès dans le SIEM, principe du moindre privilège avec accès temporaires.

Notions à rechercher et apprendre

- Zero Trust : principes NIST SP 800-207, micro-segmentation, politique dynamique, PEP/PDP.
- Protocoles d'identité : OAuth 2.0, OpenID Connect (flux, jetons, scopes), SAML 2.0, LDAP, SCIM.
- Authentification forte : TOTP, WebAuthn / FIDO2 / passkeys, attestation d'appareil, résistance au phishing.
- Autorisation : RBAC, ABAC, politiques (OPA/Rego), accès juste-à-temps, PAM (comptes à privilèges), enregistrement de session.
- Réseau : overlay chiffré (WireGuard maillé), identity-aware proxy, mTLS entre services.

Outils, plateformes et ressources

- Keycloak (fournisseur d'identité), Authelia ou oauth2-proxy (proxy d'authentification devant les applications), Teleport (accès SSH/Kubernetes audité avec enregistrement), Headscale/Tailscale (réseau maillé), Open Policy Agent, clés FIDO2 (YubiKey ou équivalent) ou passkeys logicielles, Vaultwarden (gestion des mots de passe restants).
- Ressources : NIST SP 800-207, documentation Keycloak et Authelia, documentation Teleport, guide Google BeyondCorp, cours « OAuth 2.0 / OIDC » de Okta Developer, guide ANSSI sur l'authentification multifacteur.

Étapes de réalisation

1. Théorie : fiches OIDC / SAML / WebAuthn avec schémas de flux ; lecture du NIST SP 800-207.
2. Conception : inventaire des applications et des accès, cartographie identité → rôle → ressource, politiques d'accès contextuelles, ADR Keycloak + Authelia + Teleport.
3. Déploiement de Keycloak (fédéré avec l'AD du projet 03), realms, clients, rôles, MFA obligatoire (TOTP puis FIDO2).

4. Mise derrière SSO de toutes les applications du lab : Grafana, Wazuh, NetBox, LabHub, Proxmox (OIDC ou via Authelia pour celles qui ne le supportent pas).
5. Accès d'administration via Teleport : SSH et Kubernetes avec certificats courts, enregistrement de session, approbation d'accès pour les rôles sensibles.
6. Réseau maillé chiffré Headscale entre postes et serveurs ; suppression des accès directs, micro-segmentation avec les NetworkPolicy et le pare-feu.
7. Politiques avancées : OPA pour des décisions contextuelles (heure, appareil conforme), accès juste-à-temps avec expiration.
8. Validation : tentative d'accès sans MFA (refusée), sans appareil connu (refusée), vérification des enregistrements de session, revue des journaux d'accès dans le SIEM.

Compétences acquises

- Architecture Zero Trust et gestion centralisée des identités.
- Maîtrise d'OAuth 2.0 / OIDC / SAML et de l'authentification résistante au phishing.
- Gestion des accès à privilèges (PAM) avec audit et enregistrement.
- Politiques d'autorisation comme code (OPA) et micro-segmentation.

Documentation et mise en valeur

Livrables : schéma d'architecture Zero Trust, cartographie des accès, politiques versionnées, procédure d'enrôlement d'un utilisateur et d'une clé FIDO2, rapport de tests d'accès refusés. Mise en valeur directe : la plateforme commune LabHub est elle-même protégée par ce SSO — un visiteur constate la page de connexion Keycloak, preuve immédiate que le projet est réel et en production.

16 · Honeypots et renseignement sur les menaces

Domaine	Sécurité défensive, threat intelligence
Niveau	Expert
Durée indicative	5 semaines (puis collecte continue)
Valorisation	Plateforme dédiée : tableau de bord public des attaques observées

Objectif et exigences

Déployer des leurres exposés sur Internet pour observer de vraies attaques, analyser les données collectées, les enrichir avec du renseignement sur les menaces et en tirer des indicateurs exploitables par le SOC. Exigences : isolation totale des honeypots (aucune possibilité de rebond vers le lab), collecte continue pendant au moins un mois, analyse statistique des attaques (origines, ports, identifiants, charges utiles), partage des indicateurs dans une plateforme de threat intelligence, respect du cadre légal et éthique.

Notions à rechercher et apprendre

- Types de honeypots : basse / haute interaction, honeytokens, canary tokens, deception technology.
- Isolation : DMZ dédiée, filtrage sortant strict, VLAN séparé, risques juridiques du rebond.
- Threat intelligence : cycle du renseignement, IOC vs TTP, formats STIX/TAXII, MISP, scoring, attribution (et ses limites).
- Analyse : familles de malwares, botnets, credential stuffing, scanners de masse (Shodan, Censys), enrichissement (GeoIP, ASN, réputation).
- Analyse de charges utiles en environnement de sandbox (bases de l'analyse de malware).

Outils, plateformes et ressources

- T-Pot (ensemble de honeypots avec tableaux de bord), Cowrie (SSH/Telnet), Dionaea, Honeytrap, OpenCanary ; MISP et OpenCTI pour le renseignement ; AbuseIPDB, VirusTotal, GreyNoise, Shodan ; Elastic/Kibana intégré à T-Pot ; VPS bon marché pour l'exposition.
- Ressources : documentation T-Pot (Telekom Security), documentation Cowrie, MISP training, documentation OpenCTI, parcours TryHackMe « Threat Intelligence », rapports annuels (ENISA Threat Landscape, Verizon DBIR).

Étapes de réalisation

1. Théorie : fiches honeypots, cycle du renseignement, formats d'IOC ; étude du cadre légal (responsabilité en cas de rebond).
2. Conception : emplacement (VPS dédié plutôt que réseau personnel), architecture d'isolation, données à collecter, ADR T-Pot vs honeypots individuels.
3. Déploiement de T-Pot sur un VPS isolé, filtrage sortant strict, surveillance de la machine elle-même.
4. Collecte pendant plusieurs semaines ; transfert sécurisé des journaux vers le lab (unidirectionnel).

5. Analyse : statistiques (pays, ASN, ports, identifiants les plus tentés), extraction des charges utiles, classement des campagnes.
6. Enrichissement et partage : import des IOC dans MISP, enrichissement via VirusTotal/AbuseIPDB, création d'un flux consommé par le SIEM (projet 11) pour bloquer ou alerter.
7. Honeytokens internes : faux comptes AD, faux partages, canary tokens dans des documents ; alerte immédiate si utilisés.
8. Validation : vérifier qu'une IP observée par le honeypot est bien bloquée / détectée dans le lab ; déclencher un honeytoken et mesurer le délai d'alerte.

Compétences acquises

- Déploiement sécurisé et isolé de systèmes leurres.
- Analyse de données d'attaques réelles et production d'indicateurs.
- Utilisation de plateformes de threat intelligence (MISP, OpenCTI) et partage d'IOC.
- Intégration du renseignement dans la détection opérationnelle.

Documentation et mise en valeur

Livrables : architecture d'isolation, rapport mensuel d'observation des menaces (statistiques et graphiques), collection MISP publiée, procédure de déploiement d'un honeytoken. Plateforme dédiée : un **tableau de bord public « menaces observées »** intégré à LabHub (carte des attaques, top ports et identifiants, campagnes du mois) — très visuel, il attire l'attention sur le portfolio et démontre une capacité d'analyse.

17 · Cloud hybride sécurisé

Domaine	Cloud, réseau, sécurité
Niveau	Expert
Durée indicative	5 à 6 semaines
Valorisation	Plateforme commune ; peut héberger une partie de LabHub

Objectif et exigences

Étendre le lab vers un fournisseur cloud public et relier les deux environnements de manière sécurisée, en appliquant les bonnes pratiques d'architecture, d'identité, de réseau et de surveillance cloud, tout en maîtrisant les coûts. Exigences : tout déployé par Terraform (aucune création manuelle durable), réseau cloud privé segmenté sans accès public non justifié, identités sans clés statiques quand c'est possible, chiffrement au repos et en transit, journalisation d'audit activée et remontée au SIEM, budget mensuel plafonné avec alertes, environnement destructible et reconstructible.

Notions à rechercher et apprendre

- Modèles de service (IaaS/PaaS/SaaS), responsabilité partagée, régions et zones de disponibilité.
- Réseau cloud : VPC/VNet, sous-réseaux publics et privés, tables de routage, passerelles NAT et Internet, groupes de sécurité et NACL, VPN site à site et peering, DNS privé.
- Identité : IAM (utilisateurs, rôles, politiques), moindre privilège, rôles assumés, fédération OIDC (par exemple depuis GitHub Actions), absence de clés longue durée.
- Sécurité et surveillance : chiffrement (KMS), journaux d'audit (CloudTrail / Azure Monitor), détection managée (GuardDuty / Defender), gestion de posture (Security Hub / Defender for Cloud), CSPM open source.
- Coûts : dimensionnement, budgets, alertes, ressources à arrêter, offres gratuites.

Outils, plateformes et ressources

- AWS (offre gratuite) ou Azure (crédit d'essai) — un seul suffit ; Terraform, AWS CLI / Azure CLI, Prowler ou ScoutSuite (audit de posture), Checkov ou tfsec (analyse statique du code d'infrastructure), CloudMapper/Steampipe pour la cartographie.
- Ressources : AWS Skill Builder (parcours Solutions Architect et Security), Microsoft Learn (AZ-104 / AZ-500), AWS Well-Architected Framework, Cloud Security Alliance, documentation Terraform AWS/AzureRM, « flaws.cloud » et « CloudGoat » pour la pratique offensive cloud.

Étapes de réalisation

1. Théorie : fiches VPC, IAM, responsabilité partagée, chiffrement KMS ; estimation de coûts avant tout déploiement.
2. Conception : architecture cible (VPC segmenté, VPN vers le lab, services managés utilisés), modèle IAM, plan de journalisation, budget, ADR AWS vs Azure.
3. Socle Terraform : compte et organisation, garde-fous (budgets, alertes, restriction de régions), état distant chiffré.

4. Réseau : VPC avec sous-réseaux publics/privés, NAT, groupes de sécurité restrictifs, VPN IPsec vers OPNsense du lab, DNS privé partagé.
5. Charges de travail : déploiement d'une application (par exemple une partie de LabHub ou une réplique de sauvegarde) sur instances ou service managé, base de données chiffrée, stockage objet privé avec versionnement.
6. Sécurité : rôles IAM minimaux, fédération OIDC pour la CI, KMS, activation des journaux d'audit et transfert vers le SIEM du lab, activation de la détection managée.
7. Audit de posture avec Prowler/ScoutSuite, correction des écarts, analyse statique Checkov dans la CI.
8. Validation : destruction et reconstruction complète par Terraform, test de bascule du service vers le cloud, vérification du plafond de coûts et des alertes.

Compétences acquises

- Architecture cloud sécurisée (réseau, identité, chiffrement) et cloud hybride.
- Infrastructure as Code appliquée au cloud et CI fédérée sans secrets statiques.
- Audit de posture cloud (CSPM) et remédiation.
- Maîtrise des coûts et gouvernance d'un compte cloud.

Documentation et mise en valeur

Livrables : schéma de l'architecture hybride, dépôt Terraform public, rapport Prowler avant/après, tableau de suivi des coûts, procédure de destruction/reconstruction. Sur la plateforme commune : page projet avec le schéma hybride et le rapport de posture ; si une partie de LabHub tourne dans le cloud, le mentionner explicitement comme preuve d'exploitation réelle.

18 · Investigation numérique et réponse à incident (DFIR)

Domaine	Forensique, réponse à incident
Niveau	Expert
Durée indicative	6 semaines
Valorisation	Plateforme commune : rapports d'investigation et chronologies

Objectif et exigences

Acquérir la capacité d'investiguer un incident : collecter des preuves de manière fiable, analyser disque, mémoire et réseau, reconstituer une chronologie, identifier la cause initiale et produire un rapport d'incident exploitable. Exigences : chaîne de conservation respectée (empreintes, horodatages, copie de travail), analyse conduite sur un incident réellement joué dans le lab (attaque du projet 12 ou 19), chronologie complète des actions de l'attaquant, rapport avec recommandations, procédures de réponse mises à jour ensuite.

Notions à rechercher et apprendre

- Cycle de réponse à incident (NIST SP 800-61) : préparation, détection, analyse, confinement, éradication, rétablissement, leçons.
- Ordre de volatilité, acquisition (disque bit à bit, mémoire vive), intégrité (hachage), chaîne de conservation, aspects légaux.
- Artefacts Windows : MFT, journaux d'événements, registre, prefetch, amcache, shimcache, jump lists, USN journal, navigateurs.
- Artefacts Linux : journaux, bash history, systemd, fichiers modifiés, persistance (cron, services).
- Analyse mémoire : processus, injections, connexions, credentials en mémoire.
- Réseau : analyse de captures, extraction de fichiers, détection de canaux de commande et contrôle ; « super timeline ».

Outils, plateformes et ressources

- Velociraptor (collecte à distance à grande échelle), KAPE, FTK Imager, dd/dc3dd, Volatility 3, Autopsy / Sleuth Kit, Plaso/log2timeline + Timesketch, Eric Zimmerman Tools, Wireshark / Zeek, YARA, CyberChef ; REMnux pour l'analyse de malware.
- Ressources : « The DFIR Report » (cas réels), SANS DFIR posters et cheat sheets, cours TryHackMe « DFIR » et CyberDefenders (exercices d'investigation), documentation Volatility et Velociraptor, livre « Incident Response & Computer Forensics ».

Étapes de réalisation

1. Théorie : fiches cycle de réponse, ordre de volatilité, artefacts Windows/Linux.
2. Préparation : déploiement de Velociraptor sur le parc du lab, activation des journaux nécessaires (Sysmon, auditd), procédures d'acquisition écrites, trousse d'outils prête.
3. Jouer un incident : exécuter une chaîne d'attaque complète (projet 12/13/19) sur des machines du lab, sans prendre de notes côté attaquant pour rendre l'investigation réaliste.

4. Détection et déclenchement : partir de l'alerte du SIEM, ouvrir un cas dans TheHive.
5. Collecte : acquisition mémoire et disque de la machine compromise, hachage et copie de travail, collecte à distance des artefacts sur les autres machines.
6. Analyse : mémoire (Volatility), disque (Autopsy, outils Zimmerman), réseau (Zeek/Wireshark) ; recherche de persistance et de mouvement latéral ; règles YARA sur les binaires trouvés.
7. Chronologie : construction d'une super timeline (Plaso + Timesketch) reconstituant les actions de l'attaquant heure par heure.
8. Confinement, éradication, rétablissement ; rapport d'incident avec cause initiale, impact, indicateurs, recommandations ; mise à jour des détections et du durcissement.

Compétences acquises

- Acquisition de preuves respectant l'intégrité et la chaîne de conservation.
- Analyse forensique disque, mémoire et réseau, connaissance des artefacts.
- Construction de chronologies et identification de la cause initiale.
- Conduite d'une réponse à incident complète et rédaction du rapport.

Documentation et mise en valeur

Livrables : procédures d'acquisition, journal d'investigation horodaté, chronologie Timesketch exportée, rapport d'incident complet, indicateurs partagés et nouvelles règles de détection. Sur la plateforme commune : page « investigations » avec les rapports (scénarios de lab, donc publiables intégralement) — un rapport DFIR bien rédigé est l'une des meilleures preuves de compétence blue team.

19 · Simulation d'adversaire et purple teaming

Domaine	Red team automatisée et amélioration de la détection
Niveau	Expert
Durée indicative	5 à 6 semaines
Valorisation	Plateforme dédiée possible : suivi de la couverture ATT&CK dans le temps

Objectif et exigences

Mesurer et améliorer méthodiquement la capacité de détection du lab en simulant les techniques d'adversaires connus de façon reproductible et automatisée, puis en comblant les lacunes détectées. Exigences : simulations exécutées automatiquement et sans risque (techniques non destructives), résultat de chaque technique classé (détectée, journalisée sans alerte, non vue), couverture mesurée dans le temps, chaque lacune donnant lieu à une nouvelle règle de détection ou à du durcissement, campagne complète reproduisant le mode opératoire d'un groupe réel.

Notions à rechercher et apprendre

- Différence entre test d'intrusion, red team, purple team et simulation d'adversaire.
- MITRE ATT&CK approfondi : mode opératoire de groupes, émulation de plans (Adversary Emulation Library du Center for Threat-Informed Defense).
- Commande et contrôle : fonctionnement d'un implant, canaux (HTTPS, DNS), évasion (limites éthiques), détection des balises.
- Ingénierie de détection : cycle détection → test → ajustement, notion de « detection as code », métriques (délai de détection, taux de couverture).
- Mesure : matrice ATT&CK Navigator, scoring de la couverture, tests de régression de détection.

Outils, plateformes et ressources

- Atomic Red Team (tests unitaires par technique), MITRE Caldera (simulation automatisée), Sliver ou Havoc (C2 open source, usage strictement en lab), Invoke-AtomicRedTeam, VECTR (suivi des campagnes purple team), ATT&CK Navigator ; côté détection : Wazuh/Elastic, dépôt Sigma, Falco.
- Ressources : documentation Atomic Red Team et Caldera, Adversary Emulation Library (MITRE CTID), « SANS Purple Team » ressources gratuites, blog Red Canary (Threat Detection Report), documentation VECTR.

Étapes de réalisation

1. Théorie : fiches sur l'émulation d'adversaire, lecture d'un plan d'émulation (par exemple APT29) et du Threat Detection Report de Red Canary.
2. Conception : périmètre et règles de sécurité des simulations (machines cibles, techniques exclues), plan de campagne, tableau de suivi VECTR, ADR Caldera vs exécution manuelle.
3. Baseline : exécution d'Atomic Red Team technique par technique sur une machine témoin, classement des résultats (détectée / journalisée / non vue).
4. Comblement des lacunes : nouvelles règles Sigma, activation de journaux manquants, durcissement ; ré-exécution jusqu'à détection.

5. Automatisation : orchestration des tests via Caldera et un pipeline planifié ; tests de régression de détection à chaque changement du SIEM.
6. Campagne complète : émulation du mode opératoire d'un groupe réel avec un C2 en lab (accès initial simulé, persistance, découverte, mouvement latéral, exfiltration factice).
7. Analyse de la campagne avec l'équipe défensive (soi-même) : ce qui a alerté, ce qui a manqué, délais ; alimentation du projet 18 (investigation) avec les traces produites.
8. Publication de la matrice de couverture ATT&CK avant / après et des métriques d'amélioration.

Compétences acquises

- Simulation d'adversaire reproductible et automatisée.
- Ingénierie de détection dirigée par la menace (threat-informed defense).
- Mesure objective d'une posture de détection et suivi dans le temps.
- Manipulation maîtrisée d'infrastructures de commande et contrôle en environnement contrôlé.

Documentation et mise en valeur

Livrables : plan de campagne, tableau de résultats par technique, matrices ATT&CK avant/après, règles de détection ajoutées, rapport purple team. Plateforme dédiée envisageable : un **suivi de couverture de détection** intégré à LabHub (matrice ATT&CK colorée, historique des campagnes, délai moyen de détection) : c'est l'un des livrables les plus différenciants pour un profil sécurité.

20 · Gouvernance, analyse de risques et audit du lab

Domaine	GRC (gouvernance, risque, conformité)
Niveau	Expert (projet de synthèse)
Durée indicative	5 à 6 semaines
Valorisation	Plateforme dédiée possible : registre des risques et tableau de conformité

Objectif et exigences

Traiter le lab comme un système d'information d'entreprise et lui appliquer une démarche de gouvernance complète : politique de sécurité, analyse de risques, plan de traitement, indicateurs, audit interne et amélioration continue. C'est le projet qui relie tous les autres et démontre la capacité à parler sécurité avec une direction, pas seulement avec des machines. Exigences : périmètre et actifs formellement inventoriés, analyse de risques menée avec une méthode reconnue, plan de traitement chiffré et priorisé et rattaché aux projets techniques 01 à 19, audit interne avec constats et preuves, indicateurs suivis dans le temps, documentation utilisable telle quelle comme modèle professionnel.

Notions à rechercher et apprendre

- Normes et référentiels : ISO 27001 (système de management) et 27002 (mesures), NIST CSF 2.0 (fonctions gouverner, identifier, protéger, détecter, répondre, rétablir), CIS Controls v8, RGPD pour les données personnelles.
- Analyse de risques : méthode EBIOS Risk Manager (ateliers, sources de risque, scénarios stratégiques et opérationnels), ou ISO 27005, notions de menace, vulnérabilité, vraisemblance, gravité, risque résiduel.
- Traitement du risque : réduire, transférer, éviter, accepter ; plan de traitement, propriétaire du risque, échéance.
- Pilotage : politique de sécurité (PSSI), procédures, indicateurs et tableaux de bord, revue de direction, audit interne (ISO 19011), non-conformités et actions correctives.
- Gestion des vulnérabilités et des actifs comme processus continus.

Outils, plateformes et ressources

- Modèles ANSSI (EBIOS RM, guides d'hygiène), CIS Controls Assessment Tool (CIS-CAT / CSAT), tableur ou outil GRC open source (Eramba, SimpleRisk), NetBox comme inventaire d'actifs, OpenVAS / Greenbone pour la gestion des vulnérabilités, Grafana pour les indicateurs.
- Ressources : guides ANSSI (EBIOS Risk Manager, « Guide d'hygiène informatique »), MOOC SecNumacadémie (gratuit), NIST CSF 2.0 et ses quick start guides, texte des normes ISO 27001/27002 (via bibliothèque ou achat), CIS Controls v8 (téléchargement gratuit), cours « ISO 27001 Foundation » en ligne.

Étapes de réalisation

1. Théorie : fiches ISO 27001 vs NIST CSF vs CIS Controls, principes d'EBIOS RM, vocabulaire du risque.
2. Cadrage : définir l'organisation fictive (activité, enjeux, parties prenantes), le périmètre du système d'information (le lab), les besoins de sécurité (disponibilité,

intégrité, confidentialité, traçabilité) par actif.
3. Inventaire des actifs depuis NetBox : matériel, VM, services, données, comptes ; classification et valeur métier.
4. Analyse de risques EBIOS RM : sources de risque et objectifs visés, scénarios stratégiques, scénarios opérationnels (en s'appuyant sur ATT&CK et les observations du projet 16), évaluation de la vraisemblance et de la gravité, cartographie des risques.
5. Plan de traitement : associer à chaque risque une mesure concrète — et la relier au projet technique correspondant (segmentation → projet 01/04, MFA → projet 15, sauvegardes → projet 14, détection → projet 11) ; chiffrer l'effort, prioriser, documenter le risque résiduel accepté.
6. Rédaction du corpus documentaire : PSSI, charte utilisateur, politique de mots de passe, politique de sauvegarde, procédure de gestion des incidents, procédure de gestion des vulnérabilités, plan de continuité (lié au projet 14).
7. Gestion des vulnérabilités : scans Greenbone planifiés sur tout le lab, priorisation (CVSS + exposition), suivi des corrections, indicateur de délai de remédiation.
8. Audit interne : construire un référentiel d'audit (CIS Controls v8 ou annexe A d'ISO 27001), auditer chaque mesure avec preuves (captures, configurations, rapports des projets précédents), rédiger les constats et non-conformités, proposer des actions correctives.
9. Pilotage : définir 8 à 12 indicateurs (taux de conformité CIS, couverture ATT&CK, délai de remédiation, taux de sauvegardes vérifiées, disponibilité, nombre d'incidents), les publier dans Grafana/LabHub, tenir une « revue de direction » écrite trimestrielle.

Compétences acquises

- Conduite d'une analyse de risques avec une méthode reconnue (EBIOS RM).
- Rédaction d'un corpus documentaire de sécurité (PSSI, politiques, procédures).
- Réalisation d'un audit interne avec constats, preuves et actions correctives.
- Pilotage par indicateurs et amélioration continue ; capacité à traduire la technique en langage de risque pour une direction.

Documentation et mise en valeur

Livrables : dossier d'analyse de risques EBIOS RM, cartographie des risques, plan de traitement relié aux 19 projets techniques, PSSI et politiques, rapport d'audit interne, tableau de bord d'indicateurs, compte rendu de revue de direction. Plateforme dédiée envisageable : un **module GRC dans LabHub** présentant le registre des risques, l'état d'avancement du plan de traitement et les indicateurs de conformité — il transforme le portfolio technique en démonstration de vision globale, ce qui distingue un profil senior.

Synthèse : compétences, séquencement et mise en valeur

Compétences transversales et projets qui les démontrent

Compétence	Projets
Conception et exploitation réseau (VLAN, routage, redondance)	01, 02, 04, 07, 14
Administration systèmes Linux et Windows	01, 03, 06, 10, 14
Identité et contrôle d'accès (AD, PKI, 802.1X, SSO, MFA)	03, 05, 13, 15
Sécurité défensive et détection (SIEM, IDS, EDR, threat intel)	04, 06, 11, 16, 19
Sécurité offensive (pentest, AD, émulation d'adversaire)	12, 13, 19
Forensique et réponse à incident	11, 18, 19
Automatisation et Infrastructure as Code	08, 09, 10, 17
Conteneurs, Kubernetes et DevSecOps	09, 17
Cloud et hybridation	17, 09, 14
Résilience, sauvegardes et continuité	14, 06, 20
Gouvernance, risque, conformité et audit	10, 20, 16
Développement de plateformes de valorisation	Plateforme commune LabHub, 05, 10, 11, 16, 19, 20

Séquencement conseillé sur 12 mois

Progression indicative pour un rythme de 10 à 15 heures par semaine

Période	Projets	Objectif de la période
Mois 1-2	01, plateforme commune (socle MkDocs)	Disposer du lab et d'un endroit pour documenter dès le premier jour
Mois 3-4	02, 03	Fondations réseau et annuaire (niveau CCNA et administration Windows)
Mois 5-6	04, 05, 06	Sécurité périmétrique, PKI, observabilité : le lab devient exploitable
Mois 7-8	07, 08, 10	Accès distant, automatisation complète, durcissement mesurable
Mois 9-10	09, 11, 12	Kubernetes sécurisé, SOC opérationnel, premiers rapports de pentest
Mois 11	13, 14, 15	Purple team AD, résilience prouvée, Zero Trust devant les applications
Mois 12	16, 17, 18, 19, 20	Threat intel, cloud hybride, DFIR, émulation d'adversaire, gouvernance de synthèse

Deux précautions indispensables. D'une part, toutes les techniques offensives (projets 12, 13, 19) ne doivent être exécutées que sur vos propres machines isolées ou sur des plateformes d'entraînement autorisées : hors de ce cadre, elles sont illégales. D'autre part, un honeypot ou un service exposé (projet 16, 17) doit être hébergé hors de votre réseau personnel et strictement isolé, sinon il devient un point d'entrée réel.

Où créer une plateforme logicielle dédiée et où s'en passer. Une plateforme dédiée n'a de sens que si elle produit une valeur que la documentation ne donne pas : un état en direct, un flux de données, une mesure qui évolue. Cinq cas s'y prêtent : portail de certificats (05), tableau de bord de conformité (10), portail SOC (11), tableau de bord des menaces observées (16), suivi de couverture ATT&CK (19), auxquels s'ajoute le module GRC (20). Tous les autres projets se valorisent mieux par une page documentaire riche dans LabHub : schéma, procédure, preuves de tests, retour d'expérience. Construire LabHub une seule fois et bien, plutôt que six petites applications isolées, reste la stratégie la plus efficace.

+ Modèle de fiche portfolio pour un projet d'infrastructure ou de sécurité

Document rédigé comme guide de progression et de documentation : toutes les activités offensives décrites doivent rester dans un laboratoire isolé et autorisé. Les durées sont indicatives pour un rythme de 10 à 15 heures par semaine.